

SECURE MAIL SCOPE

SMART INDIA HACKATHON 2026

AI-Assisted Cryptographic Security Posture Assessment for Secure Email Communications

SIH26159

01 — THE STATEMENT

Problem Statement Description

Enterprise email runs on SMTP, IMAP and POP3. TLS is assumed to protect it. In practice they carry deprecated protocols, weak cipher suites, unvalidated certificates and stripped STARTTLS sessions, exposing organizations to downgrade, interception and man-in-the-middle attacks.

Build a passive forensic framework that ingests captured traffic, reconstructs sessions and TLS handshakes, validates X.509 certificates, and applies AI/ML to score risk, detect anomalies and prioritize remediation.

02 — THE REAL PROBLEM

Lack of Observability

TLS 1.3, ECDHE, MTA-STS and ACME already solve every technical weakness listed. Nothing needs inventing. The failure is observability.

Email faults are silent. Stripping STARTTLS and the mail is still delivered. Servers still accept expired certificates.

For example, HTTPS was fixed because browsers increased failure visibility. Email MUAs are unlike browsers, no enforcement chokepoint and no feedback loop, so misconfiguration increases,

Suggested Solutions for the Problem Points

PROBLEM POINT	TARGETED SOLUTION
STARTTLS is negotiated in cleartext. An in-path attacker rewrites the capability line and both ends silently fall back to plaintext.	A state machine tracking advertised, requested, accepted and upgraded. Flags stripping and plaintext authentication as live credential exposure.
Certificates are never validated. Opportunistic TLS is the default, so chain, hostname and expiry go unchecked until audit.	Full X.509 extraction with chain building, expiry, key length, signature algorithm and name matching, on real observed traffic.
Legacy senders like printers, ERP mailers and backup appliances still negotiate TLS 1.0 with plaintext authentication, and appear in no asset inventory.	Port-independent protocol fingerprinting with JA3/JA4 baselining surfaces unmanaged senders that no scanner knows exist.
Tools decode but never judge. Wireshark shows a cipher without grading it. Active scanners test what a server supports, not what was negotiated, and need live access forensics lacks.	Rules encode expert knowledge, gradient boosting classifies risk with explainable scoring, and isolation forests flag sessions abnormal for that specific environment.

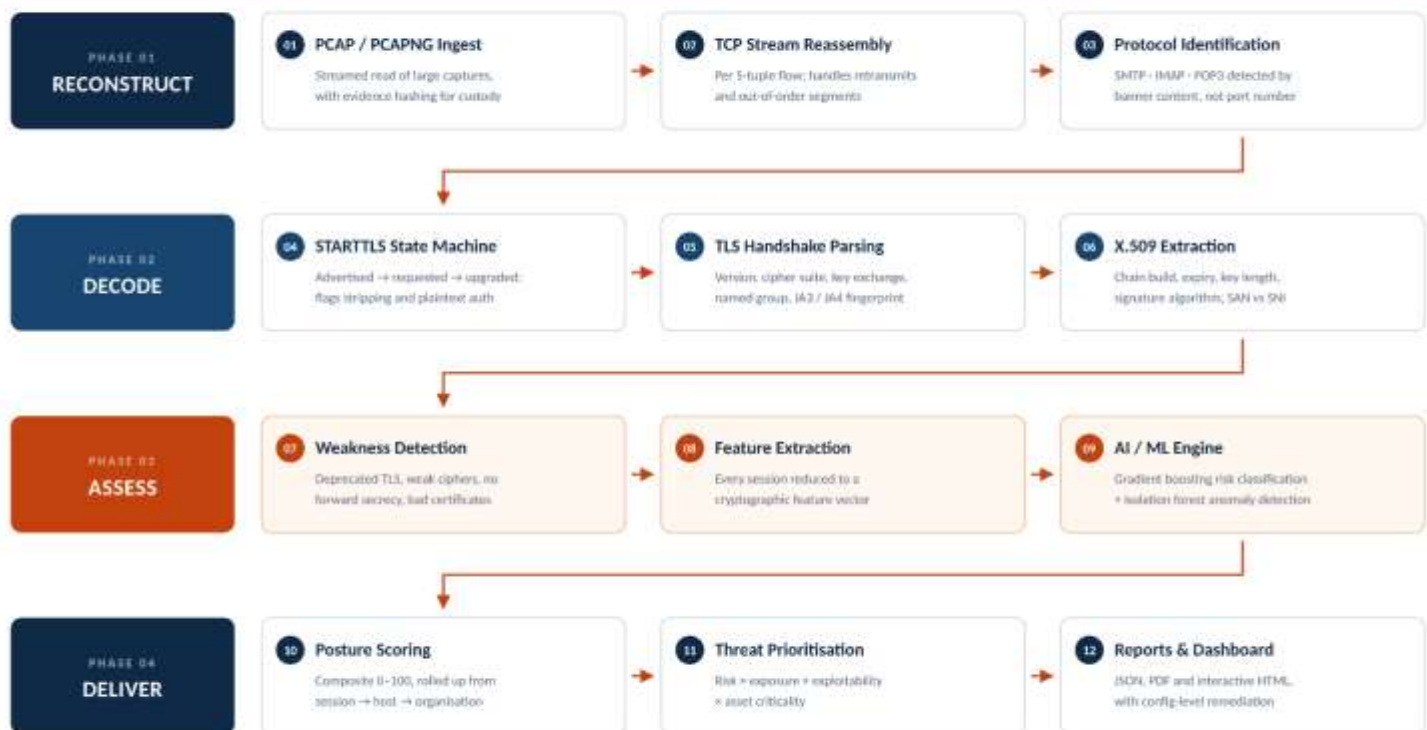
04 — PIPELINE

Framework Working

Ingest, TCP reassembly, protocol identification, STARTTLS state machine, handshake parsing, certificate validation, feature extraction, ML risk scoring and anomaly detection, prioritized findings, and JSON, PDF and dashboard export.

SecureMailScope — Analysis Pipeline

Passive PCAP forensics; reconstruct the sessions, decode the cryptography, score the risk, deliver the fix.



Fully passive — no active scanning, no traffic modification. Works on historical captures, offline hosts and air-gapped networks.

05 — TARGETS OF THE SOLUTION

Handles TLS 1.3 correctly, where certificates are encrypted and the true version hides in an extension. Detects stripping, along with encryption absence. Ranks by exposure and asset criticality, not severity alone. Returns config-level fixes mapped to NIST SP 800-52r2, PCI-DSS 4.0 and CERT-In.